

Xiao He

San Francisco, CA | xiaoh.net | Email: contact@xiaoh.net

Experienced Cloud Security Manager and Engineer with a proven track record of successfully managing geographically distributed and culturally diverse teams. Cultivates a culture of innovation while constructing engineer-friendly security solutions. Demonstrated proficiency in designing scalable and secure cloud infrastructures. Adept communicator and skilled project manager with a history of aligning security initiatives with business objectives.

Skills

- | | | |
|-----------------------------|----------------------------------|----------------------------------|
| • Cloud Architecture Review | • Identity and Access Management | • M&A Due Diligence |
| • Security Automation | • Engineering Management | • M&A Integration |
| • Security Engineering | • Risk Management | • Contract Terms Negotiation |
| • Threat Modeling | • Vulnerability Management | • Vendor Relationship Management |
| • DevSecOps | | |

Experience

Manager, Security Engineering at Credit Karma

(Aug 2024 - present)

- Oversaw GCP cloud infrastructure security (vulnerability management, container security, detection engineering) and corporate security (endpoint security, data loss prevention, public key infrastructure).
- Owned end-to-end cloud security posture; rolled out hardened Wiz CNAPP across 2,600 GCP projects spanning 6 VPC Service Control perimeters and 4 Kubernetes clusters, achieving and sustaining 0 critical issues.
- Launched "Done-For-You" (D4U) agentic AI remediation with Wiz MCP, auto-generating 300+ security PRs for engineering to address critical CVE patching and EOL findings.
- Built zero-day triage automation playbooks using Wiz and Tines for repeatable, high-urgency CVE response, and coordinated WAF and egress network controls for CVEs without immediate patches.
- Implemented automated security guardrails and policy-as-code in CI/CD pipelines, preventing insecure Kubernetes configurations from reaching production.
- Designed and published the Base Image Standard and Retirement SOP (Deprecation → Retirement → EOL Blocking → Escalation) governing the container image lifecycle through policy, agent harness, and pipeline enforcement.
- Managed CrowdStrike and FleetDM/osquery endpoint security across the Linux production fleet and macOS corporate assets.
- Implemented DLP controls across corporate infrastructure (Slack, Splunk, Google Workspace) to detect, quarantine, and prevent accidental leakage of sensitive member data, reducing false positives by 30%.
- Owned public key infrastructure (PKI) through a Go/GKE PKI automation service (Vault, Google Secret Manager, Firestore), automated certificate lifecycle for external certs, internal mTLS, and service bus.
- Built and led a team of 6 across four time zones (EST, CT, PT, IST), spanning full-time and contract staff at

varying levels, hiring and mentoring engineers across cloud and corporate security to enable career growth.

- Partnered with engineering and product leaders to develop security, product, and service strategies, including defining quarterly OKRs and reporting on KPIs in leadership forums.
- Managed cloud security and corporate security vendor relationships, contract negotiation, and renewals.

Manager, Cloud Security at Twilio

(Feb 2022 - May 2024)

- Managed a 3-year strategic cloud security maturity roadmap aligned with business top risks and NIST CSF.
- Oversaw Cloud Vulnerability Management program and developed pillar-based capabilities for scale.
- Cultivated cross-functional relationships with peer security teams, core infrastructure teams, and product teams to unblock ongoing efforts and coordinate new initiatives.
- Coordinated buy-ins and deliveries for AWS Identity Center initiative across Security, IT, and Infrastructure, successfully deploying scalable human IAM access for 1500+ engineers.
- Hired and managed a team of 8 spread globally and mentored ICs through regular career conversations.
- Managed CloudSec and Vulnerability Management vendor relationships, contract negotiation, and renewal.
- Supported ongoing ISO27001, SOC 2, PCI, and SOX audits for the enterprise.
- Managed quarterly project lifecycle with maturity roadmap and facilitated retrospectives to promote continuous learning. We:
 - Eliminated direct SSH access across account fleets for humans with AWS System Manager.
 - Automated 100% AWS Account Tagging with ownership and security classification.
 - Mitigated IAM privilege escalation with Sentinel policy deployment and permission boundary.
 - Leveraged AI to build generative IAM policy least-privilege recommendations for engineering.
 - Supported incident response and threat detection by increasing infrastructure logging coverage (CloudTrail, WAF Logs, S3 Logs) and developed incident responder access to cloud assets.
 - Developed and deployed M&A runbook and automation for Cloud Security.
 - Built self-serviced WAF solution for every edge service at Twilio.

Tech Lead / Staff Cloud Security Engineer at Twilio

(Sept 2021 - Feb 2022)

- Developed cloud architectural patterns around Org Structure, IAM, Service Mesh, K8s, and audit logging.
- Authored Twilio Cloud Security Policy revisions to incorporate Multi-Account strategy, Kubernetes, Infrastructure as Code (IaC), and compliance-driven requirements (HITRUST, PCI, HIPAA).
- Performed security architecture reviews and threat models for IAM, Networking, Storage, and Encryption.
- Drove the SPIFFE/SPIRE initiative & OPA adoption from security, conducting architectural reviews and threat models for Service Discovery and Communication.
- Conducted risk assessments, evidence gathering, and facilitated remediation for SOC 2 and PCI DSS findings.
- Supported Threat Hunting, Threat Detection, and Incident Response functions.
- Mentored junior ICs on navigating larger initiatives and planning dependencies.

Senior Cloud Security Engineer at Twilio

(Apr 2020 - Sept 2021)

- Deployed AWS Organization OU management and SCP deployment via Terraform.
- Migrated all production bastion SSH access from X.509 certificate to YubiKey One-Time-Password (OTP).
- Developed automation framework and JIRA metrics for the Cloud Vulnerability Management program.
- Built out AWS new account security onboarding automation via AWS CloudFormation StackSets.

- Performed due diligence on M&A targets and facilitated cloud environment integration.
- Collaborated with senior leaders from various business units and PCI auditors on formulating and establishing the standard cloud configuration framework throughout the enterprise.

Cloud Security Engineer at Twilio

(Aug 2018 - Apr 2020)

- Automated detection and remediation with Step Functions, AWS Lambda, and DynamoDB.
- Performed threat modeling, incident response, and IAM least-privileged analysis.
- Managed bastion network and Twilio's public key infrastructure (PKI) for production access.
- Worked as a cross-functional partner to security champions in the cloud security domain.

Co-founder & CTO at Kilter (acquired by Blackbaud)

(June 2016 - Jan 2019)

- Directed technology decisions and oversaw the development of React Native mobile and web apps.
- Designed, developed, and secured native AWS cloud infrastructure with services running Golang APIs, PHP, Python, Angular 5 website, and CI/CD pipeline.
- Interfaced with integration partners and large clients to facilitate customer adoption.
- Managed a full-stack engineering team of 5 and prioritized feature requests and workstreams.

Blogs

3 Big Transitions to go from Tech Lead to Engineering Manager

- <https://xiaoh.net/thoughts/management/2022/04/28/Tech-Lead-To-EM.html>

Alert & Remediate AWS Cloud Misconfigurations with Step Functions

- <https://xiaoh.net/thoughts/aws/2020/11/03/Vuln-Life-Cycle.html>

Time-based Control for IAM

- <https://xiaoh.net/thoughts/aws/2021/04/19/Time-based-IAM.html>

Terraform Monitoring to Your AWS Organization SCP

- <https://xiaoh.net/thoughts/aws/2021/05/20/Monitor-AWS-SCP.html>

Certifications

- Certified Information Systems Security Professional (CISSP)
- AWS Certified Security – Specialty
- AWS Solutions Architect – Associate
- AWS Certified Developer – Associate
- GIAC Security Essentials Certification (GSEC)
- AWS Cloud Practitioner